

MERIDIAN HEALTH ANALYTICS, INC. — THIRD-PARTY / V

Sample GRC portfolio artifact | Fictional company | Vendor inventory, risk tiering, and assessment st

Vendor ID	Vendor Name	Service Provided	Data Accessed
V-001	ClaimLink Corp	Claims clearinghouse / eligibility verification	PHI, claims data
V-002	AWS (Amazon Web Services)	Cloud infrastructure hosting (IaaS)	PHI, all production data
V-003	Okta	Identity provider / SSO	Authentication metadata, employee/user identities
V-004	PayStream Processing	Payment processing gateway	Payment card data (tokenized), billing info
V-005	SendGrid (Twilio)	Transactional email delivery	Email addresses, appointment reminders (limited PHI in subject lines)
V-006	DataVault Records Mgmt	Offsite physical records storage/destruction	Archived paper PHI records
V-007	QuickHire Staffing	Temporary/contract staffing agency	Employee background info (non-PHI)
V-008	CleanCo Facilities	Office cleaning services (after-hours facility access)	Physical facility access only
V-009	Figma Inc.	Product design collaboration tool	Product mockups, no PHI
V-010	BillWise Revenue Cycle	Outsourced billing/revenue cycle management	PHI, billing and claims data
V-011	Zoom Video Communications	Video conferencing, incl. telehealth-adjacent internal meetings	Occasional PHI discussed in meetings (not recorded)

ENDOR RISK ASSESSMENT

atus

PHI/PII Access?	Inherent Risk Tier	SOC 2 Type II on File?	Last Assessment Date	Assessment Score (0-100)	Risk Rating
Yes	Critical	No	2025-11-01	84	Medium
Yes	Critical	Yes	2025-11-01	96	Low
No	High	Yes	2025-11-01	91	Low
No	High	Yes	2025-11-01	88	Low
Yes	High	Yes	2025-11-01	79	Medium
Yes	High	No	2025-11-01	65	High
No	Medium	No	2025-11-01	58	High
No	Low	No			Not Assessed
No	Low	Yes	2025-11-01	90	Low
Yes	Critical	Partial (bridge letter only)	2025-11-01	71	High
Yes	Medium	Yes	2025-11-01	93	Low

Contract Renewal Date
2026-01-15
2027-03-01
2026-11-01
2026-09-15
2026-06-30
2026-04-01
2026-08-01
2026-12-01
2027-01-15
2026-05-01
2027-02-01

VENDOR SECURITY QUESTIONNAIRE — ClaimLink Corp (1

Completed by vendor point of contact | Reviewed by Vendor Risk Manager | Based on SIG Lite / HEC

#	Domain	Question
1	Governance	Does the organization have a documented, board-approved information security policy reviewed at least annually?
2	Governance	Is there a designated individual or team responsible for information security (e.g., CISO)?
3	Compliance	Has the organization completed a SOC 2 Type II audit within the last 12 months?
4	Compliance	Is the organization subject to and compliant with HIPAA as a Business Associate?
5	Data Protection	Is data encrypted at rest using AES-256 or equivalent?
6	Data Protection	Is data encrypted in transit using TLS 1.2 or higher?
7	Access Control	Is multi-factor authentication required for all remote and administrative access?
8	Access Control	Are access reviews performed on a recurring basis (at minimum quarterly)?
9	Incident Response	Is there a documented incident response plan, and when was it last tested?
10	Incident Response	What is the contractual notification timeline in the event of a breach involving our data?
11	Business Continuity	Is there a documented and tested business continuity / disaster recovery plan?
12	Subcontractors	Does the organization use subcontractors (fourth parties) with access to our data, and are they contractually flowed down the same security requirements?

Assessor Findings

- No current SOC 2 Type II report on file (renewal in progress) — drives Critical/High risk rating pending
- Access reviews at semi-annual cadence fall short of internal quarterly standard for Critical-tier vendors
- BC/DR test cadence (20 months) exceeds internal 12-month expectation for Critical-tier vendors
- Overall assessment score: 84/100 (Medium-High). Recommend conditional approval pending SOC 2 in the enterprise Risk Register.

/-001)

VAT-style structure

Vendor Response
Yes — policy last reviewed October 2025
Yes — Director of Information Security, reports to COO
No — most recent SOC 2 Type II report is dated 18 months ago; renewal in progress, expected completion Q2 2026
Yes — BAA executed with Meridian Health Analytics; internal HIPAA compliance program in place
Yes — all PHI encrypted at rest via AWS KMS
Yes — TLS 1.2 enforced on all external endpoints
Yes — MFA enforced via Okta for all employee accounts
Access reviews performed semi-annually, not quarterly
Documented IR plan exists; last tabletop test 14 months ago
Vendor contract specifies notification within 5 business days of confirmed breach
BC/DR plan documented; last full test 20 months ago
Yes, one subcontractor (cloud hosting); security requirements flowed down via subcontractor agreement

ing receipt.

irs — flagged as a contractual follow-up item.

idling PHI.

? Type II delivery within 90 days; tracked as Risk R-003

VENDOR RISK S

Inherent Risk Tiering

Assessment Score

Risk Rating Logic

Reassessment Cadence

Escalation

SCORING METHODOLOGY

Critical = PHI/PII + system access | High = sensitive data, no direct PHI | Medium = limited/indirect data exposure | Low = no sensitive data access

0-100 composite score from security questionnaire responses, weighted toward Data Protection, Access Control, and Compliance domains (40%/30%/30%)

Critical tier + score < 80 = High risk | Any tier scoring < 70 = High | Score 70-84 = Medium | Score >= 85 = Low | No score file = Not Assessed

Critical tier: annually + upon SOC 2 report renewal | High tier: annually | Medium/Low tier: every 18-24 months or upon material service change

High-risk vendors require Vendor Risk Manager + Compliance Officer sign-off to continue the relationship, with a documented remediation plan and re-assessment date.